

Roteiro — Aula 2: banco, ActiveRecord e o model User

Deck: `slides/build/aula-02-banco-de-dados-e-activerecord.pptx` (48 slides) **Apostila da turma:** `02-activerecord.md` · **Checkpoint:** `aula-02`

É a aula mais tranquila das quatro em termos de tempo. Use a folga para o console ao vivo — é o que mais fixa.

Antes de começar

- [] `git checkout aula-01` num diretório de socorro, com o banco já preparado.
 - [] `docker compose up -d` rodando no seu, para o console não travar na hora.
 - [] Terminal grande, com o `bin/rails console` já aberto e testado.
 - [] Ter em mãos um exemplo real de vazamento de senha para citar (LinkedIn 2012, 6,5 milhões de hashes SHA-1 sem salt — quebrados em dias).
 - [] Conferir quem não terminou a prática da Aula 1 e resolver nos primeiros 10 minutos.
-

Cronograma

Relógio	Slides	Bloco	Min
00:00	1–3	Abertura e retomada	6
00:06	4–9	Banco, transação, Postgres, container	18
00:24	10–15	ActiveRecord, ActiveSupport, <code>blank?</code>	18
00:42	16–19	Migrations e <code>schema.rb</code>	20
01:02	20–25	Senha: hash, bcrypt, <code>has_secure_password</code>	20
01:22	—	Intervalo	10
01:32	26–29	Validações e normalização	15
01:47	30–36	Associações e N+1	22
02:09	37–40	Concerns	15
02:24	41–45	Console ao vivo, seeds, fixtures, teste	17
02:41	46	Prática	35
03:16	47–48	Recapitulação e fim	4

Dá 3h20. Cortes possíveis:

- Slide 5 (`O MODELO RELACIONAL` , marcado `# CORTÁVEL`) se a turma já viu SQL. **–5 min**
- Slide 36 (`A ARMADILHA N+1`) — fica na apostila. **–5 min**
- Encurtar a prática para 25 min e mandar o resto de casa. **–10 min**

Bloco a bloco

00:00 — Retomada (1–3)

O slide 3 é a ponte: *"temos uma API que responde. Ela não guarda nada. Reiniciou, esqueceu tudo. Hoje ela ganha memória."*

00:06 — Banco (4–9)

Transação (6–7) é o slide que eles vão precisar na Aula 3. Use o exemplo do dinheiro: debitar de um e creditar no outro têm que ser a mesma operação; debitar sozinho é dinheiro que sumiu.

Aponte o `!` no slide 7 e explique: dentro da transação você **quer** que estoure, porque `save` devolve `false` em silêncio e a transação seguiria feliz gravando metade.

No 8, a frase: *"desenvolver no mesmo banco da produção elimina uma categoria inteira de bug."*

00:24 — ActiveRecord (10–15)

O slide 13 é o que causa espanto em quem vem de Django: **a classe não declara nada**.

```
class User < ApplicationRecord
end
```

Diga: *"isso já tem todas as colunas. A fonte da verdade é a migration, não a classe."*

15 é para rodar no console, não para ler:

```
nil.blank?      # true
"".blank?       # true
"  ".blank?     # true
0.blank?        # false    ← aqui alguém vai reclamar
```

E a pegadinha que vem de Python: em Ruby, `if 0` executa. `if ""` executa. Só `nil` e `false` são falsos.

00:42 — Migrations (16–19)

Gere uma migration ao vivo:

```
bin/rails generate migration CreateUsers
```

Mostre o arquivo criado, o timestamp no nome, e diga que é ele que define a ordem.

O slide 18 tem o ponto mais importante do bloco: índice único é restrição do banco, validação é mensagem bonita. Duas requisições simultâneas passam pela validação juntas — as duas consultam, as duas não acham ninguém — mas só uma vence o índice.

No 19, a regra: **nunca edite migration que já rodou em produção**. Crie outra.

01:02 — Senha (20–25)

O bloco mais importante da aula inteira.

- **21** — comece pelo susto. Cite o vazamento que você separou.
- **22** — hash não é criptografia. Criptografia tem volta; hash não.
- **23** — por que bcrypt e não SHA-256: SHA é rápido, **e é esse o problema**. GPU testa bilhões por segundo. bcrypt é lento de propósito, com custo ajustável.
- **24** — desmonte o hash na tela: versão, custo, salt, digest.

Demonstre no console — é o momento em que a ficha cai:

```
BCrypt::Password.create("senha123")
BCrypt::Password.create("senha123")  # rode DE NOVO
```

São diferentes. É o salt. Pergunte por que, antes de responder.

01:32 — Validações (26–29)

O 29 (normalizar antes de validar) fecha com o 18: se você não normaliza, o índice único não serve para nada, porque o banco acha que `Ana@UFOP.br` e `ana@ufop.br` são valores diferentes.

01:47 — Associações (30–36)

Bloco novo, e é o que eles mais vão usar no primeiro projeto de verdade.

A regra que resume tudo (slide 32): **a chave estrangeira fica no lado "muitos"**. Quem carrega a coluna usa `belongs_to`; quem é apontado usa `has_many`.

No console:

```
ana = User.first
ana.login_events.create!(client: "mobile", occurred_at: Time.current)
ana.login_events.count
ana.login_events.recentes.first.user.name    # e volta
```

Demonstre o N+1 de verdade (36) — com o log na tela:

```
User.all.each { |u| puts u.login_events.count }    # conte as consultas
User.includes(:login_events).each { |u| puts u.login_events.count }
```

A diferença no log é o argumento. Nenhum slide convence tanto.

02:09 — Concerns (37–40)

A ponte com a Aula 1: *"lembram do módulo que se inclui numa classe? Isto aqui é ele, com nome de Rails."*

O slide 40 tem as três decisões — a que mais rende é a terceira: `email_verified_at` é data, não booleano, porque um dia alguém vai abrir chamado perguntando *quando* a conta foi ativada.

02:24 — Console e testes (41–45)

O slide 45 (`authenticate_by_email`) merece atenção: o ataque de temporização. Se a resposta volta em 1ms quando o e-mail não existe e em 100ms quando existe, dá para descobrir quem tem conta cronometrando. Guarde — volta na Aula 3.

02:41 — Prática (46)

Circule. Os pontos onde travam:

- esqueceram `db:migrate` depois de criar a migration;
- escreveram `has_secure_password` sem adicionar a gem `bcrypt` no Gemfile;
- `matricula` com máscara (`20.112-34`) falhando na validação — é exatamente o motivo de `normalize_matricula` existir.

Perguntas que vão aparecer

Pergunta	Resposta curta
"Por que não SQLite? É mais simples."	Uma escrita por vez no banco inteiro. Num servidor com várias requisições, trava.
"Dá para descriptografar o <code>password_digest</code> ?"	Não. Não é criptografia, é hash: caminho só de ida. Nem você consegue ver a senha do usuário — e isso é a intenção.
"Por que o bcrypt é lento? Isso não é ruim?"	É lento de propósito . 100ms para você é nada; para quem tenta bilhões de senhas, é o que inviabiliza.
"Se eu já valido no model, para que o índice único?"	Concorrência. Duas requisições ao mesmo tempo passam pelas duas validações e só uma vence o índice.
"Por que não <code>t.boolean :email_verified?</code> "	Porque booleano responde "sim" e data responde "sim, dia 12 às 14h". Um dia alguém vai perguntar quando.
"Posso apagar uma migration antiga e refazer?"	Na sua máquina, sim. Depois que rodou em produção, nunca — crie outra.
" <code>dependent: :delete_all</code> ou <code>:destroy</code> ?"	<code>delete_all</code> é um <code>DELETE</code> só, direto no banco, e não roda callback. <code>:destroy</code> carrega cada registro e roda os callbacks. Aqui não há callback, então <code>delete_all</code> é mais rápido.

Dever de casa

1. Terminar a prática.
2. Bônus: escrever o N+1 de propósito, contar as consultas no log e consertar com `includes`.
3. Ler a seção "Uma sutileza de segurança" da apostila — ela é o começo da próxima aula.